SI6007 · DESARROLLO DE SISTEMAS SEGUROS · UNIVERSIDAD EAFIT

# Vulnerabilidades de un marketplace

Silk Road (2013) frente a Coupang (2025): doce años después, la misma clase de falla

Sergio Alfredo Junca Valero · 16 de octubre de 2026

**Idea central.** Un marketplace custodia el dinero y los datos de otros, así que su activo es la confianza. En los dos casos el fallo no estuvo en la criptografía sino en la gestión: una validación que se podía repetir, un servidor mal configurado, una llave que nadie revocó.

SILK ROAD · 2012
**Más de 50.000 BTC**
extraídos con retiros en rápida sucesión

COUPANG · 2025
**37,5 millones**
de personas afectadas, según el regulador

COUPANG · JUN. 2026
**US$409 millones**
de multa récord por la fuga y su manejo

## Dónde se rompe un marketplace




Los cinco números son puntos de falla que reaparecen en los dos casos; la tabla de la página 2 los compara. El 1 aparece dos veces: la misma causa en los pagos de Silk Road y en el login de Coupang.

## Los dos casos en una línea de tiempo

### Silk Road y su sucesor · 2011-2014

Mercado ilegal en la red Tor, con registro abierto (Tarbell, 2014).

| | |
|---|---|
| **2011** | El operador promociona el sitio como “altoid” y deja un Gmail con su nombre real (Aegerter, 2013). |
| **Sep. 2012** | Con al menos nueve cuentas falsas y más de 140 transacciones en rápida sucesión, James Zhong logra que el sistema pierda la cuenta de lo retirado y se lleva más de 50.000 BTC (Amick, 2022). |
| **Mar.-may. 2013** | El operador anota fugas repetidas de la IP de sus servidores (Tarbell, 2014). |
| **1-2 oct. 2013** | Arrestan a Ross Ulbricht y el FBI cierra el sitio (Tarbell, 2014). |
| **Feb. 2014** | Silk Road 2 (SR2) anuncia la pérdida de unos 4.474 BTC; su administrador la atribuye a confirmar pagos solo por el ID, que podía alterarse sin cambiar el pago (Biggs, 2014). |

**Lectura.** El dinero se perdió porque el sistema de retiros no resistió peticiones en rápida sucesión. El sitio cayó, según el expediente, por un servidor alcanzable fuera de Tor y un operador que dejó rastros; cómo lo halló el FBI se discute (Schneier, 2014).

### Coupang · 2024-2026

Gran plataforma de comercio electrónico de Corea del Sur.

| | |
|---|---|
| **Nov. 2024** | Se va un ingeniero que desarrolló parte de la autenticación; su llave de firma no se invalida de inmediato (Yang y Jin, 2026). |
| **Abr.-nov. 2025** | Según el Ministerio, el exempleado fabrica tokens de login falsos con esa llave y entra a cuentas de clientes; un programa suyo habría hecho unos 140 millones de consultas, dice Coupang (Yang y Jin, 2026). |
| **Nov. 2025** | Los clientes reciben correos amenazantes y avisan; la empresa no había detectado nada (Lee, 2026). Notifica a las autoridades más de 53 h después de informar a su CISO; el plazo es de 24 h (Yang y Jin, 2026). |
| **Feb. 2026** | El Ministerio de Ciencia concluye: “más un problema de gestión que un ataque avanzado” (Yang y Jin, 2026; traducción propia). |
| **Jun. 2026** | El regulador de datos (PIPC) multa a Coupang con 624.681 millones de wones, unos US$409 millones, entre otras faltas por notificar tarde y borrar unos cinco meses de logs pese a una orden de conservación (Gatlan, 2026; Lee, 2026). |

**Lectura.** No hizo falta un ataque avanzado: bastó una llave que debió invalidarse al salir su autor y que nadie notara el uso anómalo durante meses. Coupang discute el alcance de la fuga (Gatlan, 2026).

## Cinco puntos de falla, dos épocas

| Punto del mapa | Silk Road | Coupang | Qué hace un equipo de desarrollo seguro |
|---|---|---|---|
| **1 Una sola validación crítica**<br>A06 · Integridad | Más de 140 retiros en rápida sucesión; el sistema perdió la cuenta de lo pagado. SR2: pagos confirmados solo por ID. | Token aceptado solo por su firma: con la llave se abría cualquier cuenta (Lee, 2026). | **Planear, codificar y probar.** Modelar "¿y si falla o se repite?", retiros atómicos (ejemplo abajo) con pruebas de concurrencia y token validado también contra la sesión. **Trade-off:** latencia. |
| **2 Cuentas falsas o suplantadas**<br>A07 · Confidencialidad | Registro abierto: el exploit usó al menos nueve cuentas falsas (Amick, 2022). | Con tokens falsos, el atacante entra como un cliente legítimo. | **Planear y operar.** Límite de tasa por cuenta e IP, WAF y fail2ban (vistos en clase), tope de retiro a cuentas nuevas, MFA. **Trade-off:** fricción. |
| **3 Secretos y configuración**<br>A02, A04 · Confidencialidad | Servidor alcanzable fuera de Tor: por el CAPTCHA, dice el FBI (Tarbell, 2014); por PHPMyAdmin, dicen sus críticos (Schneier, 2014). | La llave de firma no se renovó ni se revocó de inmediato al salir el ingeniero (Lee, 2026). | **Codificar y operar.** Línea base de seguridad, paneles admin fuera de Internet, gestor de secretos con rotación y revocación el día de la baja. **Trade-off:** exige automatizar. |
| **4 Personas con acceso**<br>Gobierno · Confidencialidad | Operador con rastros propios: alias "altoid", pero Gmail y Stack Overflow con su nombre real (Aegerter, 2013). | Un exempleado conocía las fallas de la autenticación (Yang y Jin, 2026). | **Operar y gobierno.** Mínimo privilegio, segregación de funciones, soporte sin acceso a lo crítico, baja verificada. **Trade-off:** más procesos. |
| **5 Detectar y responder**<br>A09 · Trazabilidad | La fuga de IP se supo tras un DDoS (mar. 2013): detección reactiva (Tarbell, 2014). | Siete meses sin detección; avisaron los clientes; cinco meses de logs borrados (Lee, 2026; Yang y Jin, 2026). | **Operar.** Alertas por volumen anómalo por token, logs inmutables y plan de respuesta con notificación (SIC, Ley 1581; GDPR, 72 h). **Trade-off:** falsos positivos. |

OWASP Top 10:2025 (OWASP Foundation, 2025): A02 Configuración incorrecta, A04 Fallas criptográficas, A06 Diseño inseguro, A07 Fallas de autenticación, A09 Fallas de registro y alertas; en la edición 2021, Diseño inseguro era A04 y Configuración incorrecta, A05. Propiedades: las cinco vistas en clase (confidencialidad, integridad, disponibilidad, trazabilidad, no repudio).

### Ejemplo aplicable: retiro atómico

Patrón clásico de la carrera: leer el saldo y descontarlo en pasos separados (el mecanismo real de Silk Road no es público).

```
UPDATE cuentas SET saldo = saldo - :monto
 WHERE id = :id AND saldo >= :monto;
-- 0 filas afectadas: rechazar el retiro
-- Red de seguridad: CHECK (saldo >= 0)
```

### Cómo se trata cada riesgo (ISO 31000, clase del 3 de oct.)

**Evitar:** no custodiar fondos; que los retenga una pasarela regulada.

**Compartir:** seguro cibernético y contrato con la pasarela.

**Modificar:** los controles de la tabla.

**Retener:** aceptar el riesgo residual con topes, p. ej. un límite diario de retiro.

**Una objeción razonable.** "Silk Road era un negocio criminal y Coupang es una empresa legítima; compararlos es forzado." Al contrario: cambian el negocio, la época y el atacante, y el tipo de fallo se repite, lo que apunta a la causa y no al contexto. Lo que cambia es la factura: el cierre y el arresto del operador en Silk Road; unos US$409 millones y 37,5 millones de personas expuestas en Coupang. Límite: cómo halló el FBI el servidor de Silk Road sigue en disputa (Schneier, 2014) y Coupang discute el alcance de la fuga.

**Para llevar.** Antes de comprar otra herramienta, conviene listar las llaves maestras del marketplace: la validación que se puede repetir, el secreto cuya pérdida abre todas las cuentas, la persona con acceso total. Cada una necesita un dueño, una fecha de caducidad y una alerta de uso anómalo; es lo que vimos en clase con los tokens de GitHub (9 de oct.). Con esa lista, la salida del ingeniero de Coupang en noviembre de 2024 habría activado la revocación de su llave.

### Referencias


Aegerter, G. (2013, 2 de octubre). *End of Silk Road: Slip-ups in building Internet drug market led to Ross Ulbricht, court documents say*. NBC News. https://www.nbcnews.com/news/world/end-silk-road-slip-ups-building-internet-drug-market-led-flna8C11326181

Amick, S. (2022, 7 de noviembre). *U.S. Department of Justice seized over $3.36 billion in bitcoin tied to Silk Road*. Bitcoin Magazine. https://bitcoinmagazine.com/markets/us-department-of-justice-seizes-over-3-billion-bitcoin

Biggs, J. (2014, 13 de febrero). *Silk Road 2 hacked, over 4,000 bitcoin allegedly stolen*. TechCrunch. https://techcrunch.com/2014/02/13/silk-road-2-hacked-88000-bitcoin-allegedly-stolen

Gatlan, S. (2026, 11 de junio). *Coupang hit with record $409 million data breach fine in Korea*. BleepingComputer. https://www.bleepingcomputer.com/news/security/south-korea-hits-coupang-with-record-409-million-fine-over-data-breach/

Lee, J.-S. (2026, 11 de junio). *Coupang hit with record 624.6 billion won fine over data breach of 37.5 million*. Seoul Economic Daily. https://en.sedaily.com/technology/2026/06/11/coupang-hit-with-record-6246-billion-won-fine-over-data

OWASP Foundation. (2025). *OWASP Top 10:2025*. https://top10.owasp.org/2025/0x00_2025-Introduction

Schneier, B. (2014, 20 de octubre). *How did the feds identity [sic] Dread Pirate Roberts?* Schneier on Security. https://www.schneier.com/blog/archives/2014/10/how_did_the_fed.html

Tarbell, C. (2014, 5 de septiembre). *Declaration of Christopher Tarbell* (S1 14 Cr. 68 (KBF)) [Declaración jurada]. U.S. District Court, Southern District of New York. https://www.emptywheel.net/wp-content/uploads/2014/10/140905-Tarbell-Declaration.pdf

Yang, H., y Jin, H. (2026, 10 de febrero). *South Korea blames Coupang data breach on management failure, not sophisticated attack*. Reuters. https://finance.yahoo.com/news/south-korea-says-coupang-must-051616142.html